

KSA ATTENDANCE SYSTEM

Product Requirements Document

Developer Handoff Specification - Version 1.0



Document status	Approved concept / implementation PRD
Primary use case	12-week class; physical attendance primarily on Wednesdays
Primary devices	Participant: mobile-first; Course Rep/Admin: mobile + desktop
System of record	Application database; Google Sheets as human-readable reporting layer
Prepared	2 September 2026

Purpose of this document

This PRD is intentionally detailed enough for a developer who has never heard the idea before. It defines the product behavior, user journeys, data handling, permissions, edge cases, design language, security guardrails, integration behavior, quality expectations and acceptance criteria. It defines required outcomes without unnecessarily locking the implementation to one framework or vendor.

Document control and interpretation

The keywords MUST, SHOULD and MAY are used deliberately throughout this specification:

Keyword	Meaning
MUST	Required product behavior or safety/security property. An implementation that violates it is not compliant with this PRD.
SHOULD	Strongly recommended approach. A developer may choose another method if the same outcome is achieved and the decision is documented.
MAY	Optional enhancement or implementation choice that does not change the core product contract.

Implementation freedom

The PRD specifies product behavior, invariants and security boundaries. The developer is free to select languages, frameworks, cloud services, queueing systems, ORM, database libraries and UI implementation techniques, provided the resulting system meets the functional, security, privacy, accessibility and reliability requirements in this document.

Table of contents

1. Product context, vision and scope
2. Goals, non-goals and success criteria
3. Users, roles and permission model
4. Core product concepts and system rules
5. Registration, authentication and account management
6. Attendance session lifecycle
7. Participant QR check-in flow
8. Geolocation verification
9. Registered attendance-device binding and device replacement
10. Manual attendance verification and approvals
11. Course Representative experience
12. Administrator / Facilitator experience
13. Duplicate prevention, fraud resistance and auditability
14. Google Sheets integration and reporting
15. Data model and data ownership
16. API, background jobs and integration architecture guidance
17. Cybersecurity requirements and guardrails

- 18. Privacy, retention and responsible data handling
 - 19. Error handling, resilience and recovery
 - 20. Edge-case behavior matrix
 - 21. Design system and responsive UI guide
 - 22. Screen-by-screen UI specification
 - 23. Accessibility and inclusive interaction requirements
 - 24. Non-functional requirements
 - 25. Testing and quality assurance
 - 26. Observability, operations and support
 - 27. Development, deployment and engineering practices
 - 28. Delivery phases and release acceptance criteria
- Appendices: permissions, state models, sample Google Sheets, reference stack and glossary

1. Product context, vision and scope

The current attendance process is manual: participants sign a written attendance record during the physical class and the class representative later re-enters the information into Google Sheets. The class runs for approximately 12 weeks and physical attendance is expected primarily on Wednesdays. The product exists to remove paper signing and repetitive transcription while keeping attendance lightweight enough that normal participants can check in in a few seconds.

The product uses a permanent, wall-mounted QR code. The QR code itself is not a secret and is not treated as the security boundary. It points to a stable check-in route. Attendance is only valid when an authorized attendance session is open and the authenticated participant passes the attendance checks described in this PRD.

Core product idea

Permanent QR + authenticated participant + active attendance session + registered attendance device + broad venue geolocation + duplicate prevention + exception handling by a physically present Course Representative.

1.1 Operating assumptions

- There is one primary class/course deployment for this initial implementation, with an approximately 12-week duration.
- Physical sessions are normally on Wednesdays, but the product MUST NOT blindly mark every calendar Wednesday as a session. A session exists only when an authorized operator creates/opens it; this safely handles cancellations, rescheduling and exceptional weeks.
- The QR code is printed once and may be photographed, bookmarked or shared. Security MUST therefore come from server-side checks rather than QR secrecy.
- Participants primarily use smartphones. Admins and the Course Representative may use either smartphones or laptops/desktops.
- Google Sheets is required as the familiar reporting output, but the application database is the authoritative system of record.
- The product is not intended to prove with biometric certainty that a human body remained in the room for the entire class. It is intended to make casual proxy attendance materially harder than the existing paper process without creating unreasonable friction.

1.2 In-scope capabilities

- Shared login and one-time participant registration.
- Participant registration fields: full name, phone number, email, password, KSA-XX serial number, identification photograph.
- Persistent authenticated sessions so normal weekly attendance does not require retyping credentials.
- One registered attendance browser/device per participant, established at registration and replaceable only through an approval flow.
- Permanent QR check-in endpoint.
- Authorized session scheduling/opening/closing, automatic end-time closure, cancellation and auditable reopening.

- Venue geolocation verification using a configurable broad geofence and accuracy-aware exception handling.
- Manual attendance verification by Course Representative/Admin when automatic verification is unavailable or unreliable.
- Role-based administration: Participant, designated Course Representative, Administrator/Facilitator.
- Google Sheets synchronization: Master Register, dated session tabs and Summary.
- Attendance history, role management, device-change workflow, audit logging and operational health indicators.
- Responsive, mobile-first UI derived from the supplied Kora Sales Academy visual reference.

1.3 Explicitly out of scope for the MVP

- Facial recognition or automated biometric matching.
- Selfies at every attendance check-in.
- Native mobile applications unless the developer independently determines they are necessary; a responsive web application is preferred for the MVP.
- Perfect hardware fingerprinting, IMEI access, MAC address access or claims that the browser can infallibly identify a physical phone.
- Continuous participant location tracking. Location is requested only for attendance verification.
- Participant-facing Google Sheet access.
- Complex analytics, gamification, badges, dark-mode dashboards, or decorative reporting that does not support the attendance workflow.
- Enterprise multi-tenant course management unless it can be added without compromising the initial delivery.

2. Goals, non-goals and success criteria

2.1 Product goals

1. Make normal attendance after registration effectively: scan QR → automatic checks → confirmation.
2. Eliminate the need for the Course Representative to transcribe paper attendance into Google Sheets.
3. Make remote attendance and simple credential-sharing materially more difficult than the current written system.
4. Keep legitimate exception handling humane: a participant physically present should have a clear route to manual verification if GPS or device state fails.
5. Give the facilitator/admin reliable oversight without requiring them to operate attendance every week.
6. Provide an auditable record of who opened/closed sessions, who manually approved attendance, who changed roles and when attendance records were corrected.
7. Preserve data privacy by collecting and retaining only what is necessary for identity, attendance, auditability and support.

2.2 Non-goals

- The system does not promise that a participant stays for the full duration of the class after checking in.
- The system does not attempt to defeat a determined attacker with device forensics, rooted-device detection or invasive fingerprinting.
- The system does not treat Google Sheets as a transaction database.

- The system should not make normal attendance slower than the manual process it replaces.

2.3 Success metrics

Metric	Target / interpretation
Normal check-in completion	A returning participant on a healthy device/network should complete attendance in a few seconds after opening the QR destination, excluding first-time location permission.
Manual transcription	Zero routine manual re-entry of participant attendance into Google Sheets.
Duplicate records	No duplicate attendance record for the same participant and session at the database level.
Resilience	A temporary Google Sheets outage must not cause a valid attendance record to be lost.
Mobile usability	All participant flows usable at 320px+ viewport widths without horizontal page scrolling or clipped controls.
Accessibility	Core flows keyboard-operable and designed to WCAG 2.2 AA expectations where applicable.
Auditability	All privileged actions and historical corrections traceable to actor, time and reason.

3. Users, roles and permission model

Authorization is role-based and MUST be enforced on the server for every privileged operation. Hiding buttons in the UI is not authorization. The same login page is used by all account types; after authentication, the application exposes navigation and controls according to the user's roles.

3.1 Participant

- Default role for normal registrations.
- Can manage their own permitted profile fields, view their own attendance history, submit attendance, and request replacement of their registered attendance device.
- Cannot open/close sessions, view other participants' private data, approve attendance, change roles, or edit historical attendance.
- Serial number is security-significant and MUST NOT be freely editable by the participant.
- Identification photograph is security-significant and SHOULD require an approval flow to replace after initial registration.

3.2 Course Representative

The Course Representative is a normal participant account that has been assigned an additional operational role by an Administrator. Exactly one participant is designated as the active Course Representative at a time unless the product owner deliberately changes this rule later.

- Retains normal participant capabilities, including their own attendance.
- Can configure the current session's start/end window, open attendance, close attendance, view live attendance, search participants for attendance operations, and process manual verification/device-change requests.
- Can approve a participant's registered-device replacement, except their own device replacement.
- Can approve manual attendance while the relevant session is open; emergency actions **MUST** be audited.
- Cannot add/remove admins, assign their own role, promote others, remove the last admin, or silently edit historical attendance.
- May reopen a same-day session only under the limited rules in Section 6; broader historical changes are admin-only.

3.3 Administrator / Facilitator

Administrators are overseers. There may be multiple admins. They use almost the same dashboard shell as the Course Representative, but receive additional role-management, configuration, audit and historical-correction controls. An admin does not have to be an attendance participant.

- Can perform Course Representative functions as an emergency fallback.
- Can assign/change the Course Representative by selecting a registered participant, preferably by serial number.
- Can grant or revoke admin privileges for eligible accounts. The system **MUST** never allow removal of the final active administrator.
- Can review audit logs, manual approvals, device changes, session history and synchronization health.
- Can correct historical attendance with mandatory reason and immutable audit trail.
- Can configure venue/geofence settings and other protected course-level settings.
- Should primarily supervise; ordinary weekly operational work is expected to be handled by the designated Course Representative.

Capability	Participant	Course Rep	Admin
Register/login/manage own account	Yes	Yes	Yes if participant
Submit own attendance	Yes	Yes	Yes if participant
View own attendance history	Yes	Yes	Yes if participant
Open/close attendance	No	Yes	Yes
Set attendance start/end time	No	Yes	Yes

Capability	Participant	Course Rep	Admin
View live session attendance	No	Yes	Yes
Process manual attendance	No	Yes, current session	Yes
Approve participant device change	No	Yes, except self	Yes
Assign Course Rep	No	No	Yes
Add/remove admins	No	No	Yes
Historical correction	No	No	Yes, audited
View security/audit logs	No	Limited operational view	Yes

4. Core product concepts and system rules

CORE-01 Permanent QR **[MUST]**

The printed QR MUST point to a stable HTTPS check-in URL. The QR value does not rotate and MUST NOT contain participant credentials or any secret whose disclosure would authorize attendance.

Rationale: The QR will inevitably be photographed or bookmarked.

Acceptance: A copied QR opened away from the venue cannot by itself create valid attendance.

CORE-02 Database is source of truth **[MUST]**

Attendance, account, session, role, device, manual verification and audit state MUST be committed to the application database before Google Sheets is treated as updated.

Rationale: This prevents Google API availability from deciding whether attendance exists.

Acceptance: The app can reconstruct a damaged/missing Google Sheet view from database records.

CORE-03 One active attendance device **[MUST]**

Each participant MUST have at most one active registered attendance browser/device credential at a time. Approving a replacement MUST revoke the previous credential.

Rationale: Raises the cost of credential sharing while preserving a recovery route.

Acceptance: Old device can no longer submit attendance immediately after replacement approval.

CORE-04 One attendance per participant per session **[MUST]**

The database MUST enforce uniqueness on participant + attendance session, not merely disable buttons in the frontend.

Acceptance: Concurrent submissions cannot create duplicates.

CORE-05 Session-controlled validity **[MUST]**

A check-in MUST be accepted only if a non-cancelled attendance session is currently open/effective. No open session means the QR is inert for attendance purposes.

Acceptance: Scanning before open or after close produces no present record.

CORE-06 Human exception path [MUST]

A physically present participant whose automatic checks cannot be completed **MUST** receive a clear route to see the Course Representative for manual verification.

Acceptance: GPS denial, poor accuracy or lost device does not force an otherwise legitimate participant to be marked absent without recourse.

CORE-07 Audit privileged actions [MUST]

Role changes, session open/close/reopen/cancel, manual attendance, device replacement approvals, protected profile corrections and historical attendance edits **MUST** record actor, timestamp, target, action and reason where applicable.

Acceptance: An administrator can reconstruct who made a sensitive change.

5. Registration, authentication and account management

5.1 Shared login

Participants, Course Representatives and Administrators use the same login screen. The application **MAY** accept either email address or serial number as the username field; password authentication is required. Phone number is not required as a login identifier.

- There **MUST NOT** be an "I am an admin" checkbox or client-controlled role selector.
- After successful login, the server loads the user's roles and the UI routes to the appropriate home/dashboard experience.
- A participant manually navigating to an admin URL **MUST** receive an authorization failure or safe redirect; the backend **MUST** not return privileged data.
- The initial bootstrap administrator **MUST** be provisioned through a secure deployment/bootstrap process, not public registration.

5.2 Participant registration fields and validation

Field	Requirement
Full name	Required. Trim leading/trailing whitespace; collapse accidental repeated spaces. Preserve human-readable capitalization; do not make name the primary identifier.
Phone number	Required. Normalize to a consistent canonical representation (E.164 recommended where feasible). Reject obviously invalid values. Unique by default unless the product owner explicitly allows shared numbers.
Email address	Required. Trim and case-normalize for comparison. Validate format. Unique. Verification by email link/OTP is strongly recommended for account recovery and registration integrity.

Field	Requirement
Password	Required. Never log or store plaintext. Use a modern password hashing function. Permit password managers and long passphrases.
Serial number	Required. Exact canonical format KSA-XX where X is 0-9. Trim whitespace and convert lowercase/mixed-case prefix to uppercase before validation. Unique and immutable to participants.
Identification photo	Required. Recent clear face-identifiable image. Stored privately; not placed in Google Sheets. Used for human verification only; no facial recognition.

Serial-number normalization examples

"ksa-24" → "KSA-24"; " Ksa-07 " → "KSA-07". Reject KSA-7, KSA-007, KS-24, KSA-A4 and KSA24 with a clear example such as "Serial number must follow KSA-XX, for example KSA-07."

REG-01 Unique identity fields **[MUST]**

Serial number and email **MUST** be unique. Phone number **SHOULD** be unique for this deployment unless a justified shared-number policy is configured.

Acceptance: A duplicate serial registration is blocked with recovery/support guidance.

REG-02 Registration establishes attendance device **[MUST]**

On successful initial registration, the current browser/device installation **MUST** be bound as that participant's active attendance device using a server-issued random credential.

Acceptance: First successful account registration yields one active device association.

REG-03 Automatic login after registration **[MUST]**

Successful registration **SHOULD** create the authenticated session immediately rather than forcing the user back to the login screen.

Acceptance: User can continue directly to the participant home or original QR check-in intent.

REG-04 Registration success screen **[MUST]**

After registration, show confirmation including participant name and canonical serial number, explain that this browser/device is now the approved attendance device, warn that clearing browser data or switching browser may require device re-approval, and offer Continue.

Acceptance: User understands the device rule before leaving setup.

Registration integrity consideration

The KSA-XX format proves syntax, not ownership of a serial. Preferred deployment: preload or import an authorized participant roster if one exists, and validate registration against that roster. If no authoritative roster exists, use first-claim uniqueness plus admin review/recovery for disputed serials. The implementation **SHOULD** make this policy configurable rather than silently assuming format validation proves identity.

5.3 Identification photograph handling

- Allow upload from camera or photo library on mobile. A formal passport-style photo is not required; the face must simply be clear and recognizable.
- Validate actual file content, not only filename extension. Enforce a reasonable maximum size. JPEG/PNG/HEIC input MAY be accepted and normalized server-side.
- Re-encode the image server-side to remove EXIF metadata (including embedded GPS where present) and reduce attack surface.
- Store in private object storage or protected filesystem outside the public web root. Access only through authenticated/authorized routes or short-lived signed URLs.
- Do not expose the photo to other participants. Course Rep/Admin may view it only for legitimate identification/administration purposes.
- Replacing the identification photo SHOULD require admin or Course Rep verification because the photo is part of the manual-identity control.

5.4 Account recovery and profile editing

- Forgot-password flow SHOULD use verified email. Password reset does not by itself make a new device an approved attendance device.
- Changing email SHOULD require current-password re-authentication and verification of the new email.
- Name and phone may be editable with re-authentication; changes are audited if they affect administrative records.
- Serial number cannot be self-edited. Admin correction requires reason and must preserve identity linkage/history.
- Logging in from a new device is allowed for account access, but attendance submission remains blocked until the device-change process is approved.

6. Attendance session lifecycle

A session represents one actual physical attendance event. It is not simply a date. This prevents cancelled Wednesdays from becoming absences and preserves a reliable audit trail.

State	Meaning	Attendance effect
DRAFT / CONFIGURING	Operator is setting start/end details; optional implementation state.	No attendance accepted.
SCHEDULED	Optional state when a future start time has been configured and explicitly activated.	No attendance until effective start.
OPEN	Attendance window is active.	Eligible participants may check in.
CLOSED	Session ended normally or automatically.	No new automatic check-ins.

State	Meaning	Attendance effect
CANCELLED	Session invalidated (e.g., opened by mistake/no class).	Does not count toward attendance percentage.

SES-01 Create/open attendance [MUST]

Course Rep/Admin can configure start and end time and explicitly open/schedule the session. Start defaults to current time. A future start MAY be supported; if used, attendance becomes valid only at that future effective time. Backdating MUST NOT create retroactive check-ins.

Acceptance: An attendance session has date, effective start, end, opened/created by and current state.

SES-02 Automatic closure [MUST]

The session MUST automatically close at its configured end time even if the Course Representative forgets. Manual close may happen earlier.

Acceptance: After end time, new check-ins are rejected and closed_at/closed_by=SYSTEM is recorded for automatic closure.

SES-03 One active session [MUST]

The system MUST prevent two simultaneously active attendance sessions for this course deployment unless future multi-course support explicitly changes this rule.

Acceptance: Opening a second session while one is open is blocked.

SES-04 Cancellation [MUST]

Admin and appropriately authorized Course Rep workflow MUST support cancelling an accidentally created/opened session. Cancelled sessions do not count in summary denominators.

Acceptance: Summary excludes cancelled session; audit records cancellation actor/time/reason.

SES-05 Reopening [MUST]

Reopening a closed session MUST be explicit and audited. Course Rep MAY reopen only a same-day session within a reasonable operational window and must provide a reason; Admin may reopen/correct more broadly. Reopening continues the same session rather than creating a duplicate dated session.

Acceptance: Audit shows original close and reopen events; duplicate attendance uniqueness remains intact.

SES-06 No-class Wednesday [MUST]

If no authorized session is created/opened, no attendance tab should be counted and nobody is marked absent merely because it is Wednesday.

Acceptance: Cancelled/no-class week does not reduce attendance percentage.

7. Participant QR check-in flow

7.1 Returning participant - ideal path

1. Participant arrives at the venue and scans the permanent QR with the phone camera (or opens the same stable URL from a bookmark).
2. The web app loads the check-in route over HTTPS.
3. Server verifies an authenticated participant session. If missing, route to login and return to check-in automatically after success.

4. Server verifies an attendance session is currently effective/open.
5. Server verifies the browser presents the active registered attendance-device credential for that participant.
6. Server verifies the participant does not already have an attendance record for this session.
7. Browser requests/reads current geolocation. Server evaluates venue distance and reported accuracy.
8. If all automatic checks pass, the backend atomically creates the attendance record in the application database.
9. The participant sees a simple success confirmation containing name/serial, date and check-in time. Google Sheets synchronization happens asynchronously and does not block the success message.

Normal weekly UX target

For a returning participant whose browser remains logged in and location permission is already granted, the visible experience should feel like: Scan QR → brief verification → "You're present".

7.2 First-time QR visitor

- If not registered, present Login and Create Account options.
- If the user registers from the QR route, preserve the intended destination. After successful registration and automatic login, continue directly into attendance verification; do not require another QR scan.
- The first attendance may require the browser's location permission prompt. Explain why location is needed before triggering the browser prompt.

7.3 Participant-visible outcomes

Situation	Participant message / action
Attendance not open	"Attendance is not currently open." No pending record.
Attendance closed	"Today's attendance session has ended." No automatic record.
Already present	"You're already checked in" plus original recorded time. Do not create another record.
Location verified	"You're present" plus check-in time.
Location unavailable/too inaccurate	Explain inability to verify, offer Try Again and instruct physically present user to see Course Rep.
Clearly outside venue	Explain that attendance can only be recorded at the venue. Do not accuse user of fraud.
Unregistered/new attendance device	Explain device is not approved for attendance; offer Request Device Change.

Situation	Participant message / action
Network problem before DB commit	Show retryable connection error. Do not claim attendance was recorded.
Google Sheets down after DB commit	Still show attendance success; Sheets issue is administrative/internal.

8. Geolocation verification

Geolocation is used to establish reasonable proximity to the venue, not to prove that the participant is inside a particular seat or room. Indoor GPS can be inaccurate, so the system **MUST** use a generous, configurable geofence and consider the browser-reported accuracy value.

8.1 Venue configuration

- Admin configures venue latitude and longitude.
- Admin configures geofence radius. Recommended initial default: approximately 200 metres, adjustable after real-world testing within a roughly 100-300 metre range depending on the venue.
- Admin configures a maximum automatic-acceptance accuracy threshold. Recommended initial value: approximately 150 metres; tune based on observed devices and environment.
- Configuration changes are privileged and audited.

8.2 Verification algorithm (required behavior, implementation flexible)

1. Request a fresh/high-accuracy browser location over HTTPS. Do not use a stale cached position as the sole basis for attendance.
2. Calculate great-circle distance from the configured venue (e.g., Haversine or an equivalent correct geospatial calculation).
3. If accuracy is within the configured acceptable threshold and distance is within the geofence radius: automatic PASS.
4. If the location is close enough that uncertainty makes a hard decision unreliable, or reported accuracy is worse than the automatic threshold: do not falsely reject; route to retry/manual verification.
5. If distance is clearly outside the geofence and the reading is sufficiently reliable: automatic REJECT for remote attendance.
6. If permission is denied, location service is unavailable, browser does not support it, or acquisition times out: explain and offer retry/manual verification for a physically present participant.

Do not overfit GPS

Do not use a 5-10 metre radius. The objective is to distinguish "around the venue" from "kilometres away", while preventing indoor GPS variance from punishing legitimate attendees.

8.3 Location data storage

- By default, Google Sheets stores only a result such as Verified / Manual Approval, not exact latitude/longitude.
- The application SHOULD avoid long-term storage of exact participant coordinates. Prefer storing verification result, rounded distance and reported accuracy only when needed for troubleshooting/audit.
- If precise coordinates are temporarily stored, define a short retention period and delete/anonymize them automatically.
- Location MUST NOT be collected continuously or outside an explicit attendance attempt.

9. Registered attendance-device binding and device replacement

"Device" in this PRD means the browser/device installation recognized by a strong, random server-issued credential. A normal website cannot reliably access IMEI, MAC address or an immutable hardware serial number. The UI may say "registered attendance device" for simplicity, but the implementation must not claim perfect hardware identity.

9.1 Device credential

- On registration, create a cryptographically random device credential and associate it with the participant as ACTIVE.
- Prefer a Secure, HttpOnly, first-party cookie or another appropriately protected persistent mechanism. If a raw token is stored server-side, store a one-way hash where practical so a database leak does not immediately expose usable device tokens.
- Device credential is separate from the ordinary login/authentication session. Logging out MUST NOT automatically erase the server-side device binding.
- Attendance submission requires both valid user authentication and the active registered attendance-device credential.
- Clearing browser/site data or switching browsers may remove the credential and therefore triggers the new-device flow rather than granting a fresh identity.

DEV-01 New-device login behavior [MUST]

A participant may log into their account on another device for normal account access, but attendance submission MUST be blocked until that browser is approved as the active attendance device.

Acceptance: Correct password on another phone is insufficient to mark attendance automatically.

DEV-02 Replacement request [MUST]

On an unrecognized device, the participant can request a device change. The request is associated with the logged-in participant and current candidate device, and the UI instructs them to physically see the Course Representative/Admin for identity verification.

Acceptance: Course Rep sees a pending device request with participant photo and serial.

DEV-03 Approval [MUST]

Course Rep/Admin verifies the person against the protected identification photo. Approval activates the candidate device and immediately revokes the previous active device.

Acceptance: Exactly one active device remains.

DEV-04 Course Rep self-approval [MUST]

The Course Representative MUST NOT approve their own attendance-device replacement. An Administrator must approve it.

Acceptance: Self-service privilege escalation path is prevented.

DEV-05 Device history [MUST]

Maintain device registration/revocation history including first seen, approved by, approval time, revocation time and reason. Do not put raw tokens in audit logs.

Acceptance: Repeated replacements are reviewable without exposing secrets.

User warning during registration

Tell users that the current browser becomes their attendance device, that private/incognito mode should not be used, and that clearing site data or changing browser may require Course Representative approval.

10. Manual attendance verification and approvals

Manual verification is the deliberate fallback for legitimate participants who are physically present but cannot complete an automatic check. It is not a generic bypass button and must be auditable.

10.1 Preferred manual-verification flow

1. Participant attempts attendance.
2. Automatic verification cannot complete (e.g., location permission denied, poor GPS accuracy, location service unavailable).
3. System creates or exposes a pending manual-verification case where appropriate and tells the participant to go to the Course Representative.
4. Course Representative opens the pending request. The UI shows full name, serial number, large identification photo, reason for manual review and attempt timestamp.
5. Course Representative physically compares the person standing in front of them to the registered photo.
6. Course Representative selects Approve Attendance or Reject. Approval creates the single attendance record with method=MANUAL and approver identity. Rejection is logged.
7. Participant can tap Check Approval Status or the page may poll conservatively while open. On approval, show attendance confirmed.

10.2 Emergency manual attendance

There must be a controlled emergency path for cases where the system did not create a pending request but the participant is visibly present (for example, a catastrophic inaccurate location reading). Course Rep/Admin may search the participant and create a manual attendance record only during an eligible session, after physical photo verification, and MUST select or enter a reason. Historical/emergency changes after the operational window are admin-only.

10.3 Manual approval security rules

- Manual approval is subject to the same participant+session uniqueness constraint as automatic attendance.
- The Course Representative cannot manually approve themselves through a bypass path if the action would evade the registered-device or identity checks; use an Administrator for privileged self-exceptions.
- The photo must be large enough on mobile to make visual comparison practical.
- Manual approvals must appear in the attendance record as Manual Approval, not masquerade as location-verified QR attendance.
- Admin overview must expose who approved each manual attendance and why.

11. Course Representative experience

The Course Representative uses the same product design language as everyone else, with an operational dashboard. The primary question on the screen is always: Is attendance open, and what needs attention?

11.1 Dashboard when attendance is closed

- Prominent status: Attendance Closed.
- Date/context for today.
- Primary action: Open Attendance.
- Before opening: start time (default now) and end time, with clear validation that end is after start.
- Secondary cards/list items: pending device changes, recent sessions, registered participant count, sync warnings if any.

11.2 Dashboard when attendance is open

- Prominent green/positive status: Attendance Open.
- Show effective time window and live present count.
- Primary operational action: Close Attendance.
- Link/button to View Attendance.
- Manual Verification queue with count.
- Device Change queue with count.
- Google Sheets sync warning only when actionable; do not clutter normal operation.

11.3 Live attendance

Course Rep can view a lightweight live list of participants already present. On mobile this is a card/list; on desktop a compact table is appropriate. The list should refresh automatically using polling, server events, WebSocket or another reasonable technique, but real-time infrastructure is not mandatory if simple refresh/polling meets UX needs.

12. Administrator / Facilitator experience

Admin uses essentially the same dashboard shell as Course Rep, with additional Administration controls rather than a separate visual product.

12.1 Admin-only capabilities

- Assign or replace Course Representative by selecting an existing participant account, preferably by serial number/search.
- Grant admin role to eligible accounts and revoke admins. Never allow zero active admins.
- Review all sessions, manual approvals, device changes, audit events and synchronization state.
- Change venue coordinates/geofence settings and other protected course configuration.
- Perform historical attendance corrections with required reason and before/after audit values.
- Trigger Google Sheets reconciliation/rebuild if needed.
- View security-sensitive operational warnings without exposing secrets or raw tokens.

12.2 Role assignment rules

- Normal registration always creates Participant, never Admin or Course Rep.
- Course Rep assignment is admin-controlled and takes effect immediately; previous Course Rep privileges are revoked when replaced.
- Adding an Admin should require a confirmation dialog and recent re-authentication for the acting admin.
- Removing an Admin should require confirmation; removing the last admin is blocked.
- All role changes are audited.

13. Duplicate prevention, fraud resistance and auditability

13.1 Database duplicate guarantee

Enforce a unique database constraint equivalent to `UNIQUE(session_id, participant_id)` for final attendance records. Handle unique-constraint races gracefully by returning the existing attendance record rather than a server error.

13.2 Defense-in-depth against account switching

- A valid password alone is insufficient: attendance also requires the participant's active registered attendance-device credential.
- A device credential **MUST NOT** be rebound automatically to another participant merely because someone logs out and logs in as a different account.
- If the same recognized device/browser is associated with one participant, attempts to register/use it as another participant's attendance device should be blocked or sent to manual review.
- Maintain optional session-level device-use checks as defense-in-depth; they are secondary to the stronger registered-device binding.
- Do not attempt invasive fingerprinting or claim hardware-level certainty. Browser-data deletion may force re-approval, which is an acceptable tradeoff for this product.

13.3 Residual fraud model

The system materially raises the effort required to fake attendance compared with a paper sheet, but it is not fraud-proof. A participant could physically travel to the venue, hand their registered phone to another person and leave. This is considered a low-value edge case because the participant has

already incurred most of the cost of attending. The system deliberately does not add per-scan selfies or biometrics to solve this.

13.4 Audit events

Event	Minimum audit details
Session open/close/reopen/cancel	actor, role, session, timestamp, configured window, reason where relevant
Manual attendance approval/rejection	actor, participant, session, timestamp, reason, prior attempt context
Device replacement	requester, old device record id, new device record id, approver, timestamps; never raw token
Role change	actor, target, old roles, new roles, timestamp
Historical attendance edit	actor, target participant/session, before value, after value, reason, timestamp
Venue/security config change	actor, old/new values, timestamp
Repeated login/security events	sanitized metadata appropriate for incident review; never passwords/tokens

14. Google Sheets integration and reporting

Use one Google Sheets workbook for the class. The application owns the data and pushes a human-readable representation to Sheets. Routine operators should not need to manually type attendance into the workbook.

14.1 Workbook structure

- Summary - cross-session participant attendance view.
- Master Register - registered participant details appropriate for administrative reporting.
- One dated tab for each actual attendance session, preferably named YYYY-MM-DD so tabs sort unambiguously.
- Cancelled sessions may remain as clearly marked CANCELLED tabs for auditability, but they do not count in summary percentages.

14.2 Master Register

Column	Notes
Serial Number	Canonical KSA-XX. Primary human identifier.
Full Name	Display name.
Phone Number	Normalized human-readable output.
Email	Normalized email.
Registered At	Timestamp.
Account Status	Optional: Active/Disabled.

Never place these in Google Sheets

Password, password hash, authentication/session token, device token, reset token, identification photograph, exact persistent GPS coordinates, secret keys or raw security logs.

14.3 Dated session tab

At session creation/opening, create or prepare a dated tab and write session metadata. During the session, present records may be appended/upserted. At close, finalize the participant list and mark registered participants without an applicable attendance record as Absent.

Field / column	Example / behavior
Attendance Date	Wednesday, 9 September 2026
Status	OPEN / CLOSED / CANCELLED
Opened At / By	Actual timestamp and actor
Closed At / By	Actual timestamp and actor or SYSTEM
Serial Number	KSA-24
Full Name	Participant display name
Status	Present / Absent

Field / column	Example / behavior
Check-in Time	Timestamp for present; blank for absent
Method	QR / Manual Approval
Location Status	Verified / Not Verified / Manual
Approved By	Only for manual records; otherwise blank

14.4 Summary tab

The Summary tab should show one participant per row and one actual non-cancelled session per date column, then totals and percentage. New session columns appear as real sessions occur. Do not use the calendar alone as the denominator.

Serial	Name	Sep 9	Sep 16	Sep 23	Total Present	Attendance %
KSA-01	Jane Doe	P	P	A	2	66.7%
KSA-02	John Ade	P	P	P	3	100%

If someone registers after earlier sessions, do not automatically invent prior absences unless the business rules establish that they were enrolled and expected to attend those sessions. Preferred representation is N/A or exclusion from the denominator until the applicability policy is known.

14.5 Sync mechanics and retry policy

GS-01 Asynchronous sync **[MUST]**

A valid attendance record is considered successful once committed to the application database. Google Sheets synchronization SHOULD happen asynchronously and MUST NOT block participant success.

Acceptance: Sheets outage after DB commit does not change participant status.

GS-02 Idempotency **[MUST]**

Every Sheets write/upsert MUST be idempotent using stable record identifiers or a unique key such as session+participant so retries cannot create duplicate rows.

Acceptance: Repeated retry results in one logical row.

GS-03 Retry schedule **[MUST]**

Use exponential/backoff-style retries. Recommended behavior: initial write immediately; quick retry after a few seconds; then roughly 1 minute, 5 minutes, 15 minutes, then every 30-60 minutes until success. Use jitter if a queue library supports it. Escalate a persistent failure to admin visibility.

Acceptance: Temporary outage self-heals without hammering Google APIs.

GS-04 Pending sync state **[MUST]**

Maintain sync_status (e.g., pending/synced/failed) and last_attempt/error metadata internally. Admin dashboard should expose unresolved sync backlog but participants should not see it as an attendance failure.

Acceptance: Admin can identify and recover unsynced records.

GS-05 Reconciliation **[MUST]**

Provide an admin-only reconciliation/rebuild mechanism that can re-derive Master Register/session/Summary outputs from the database. Manual Sheet edits must not silently overwrite the database.

Acceptance: Damaged Sheet can be reconstructed safely.

15. Data model and data ownership

The following is a logical model, not a mandated ORM/schema. The developer may normalize or combine tables differently, but the listed concepts and invariants must remain representable.

Entity	Key fields / purpose
User	id, name, phone, email, password_hash, serial_number, status, registered_at, email_verified_at
Role / UserRole	participant, course_rep, admin; assignment metadata
IdentificationPhoto	user_id, private storage key, uploaded_at, status/version
AttendanceDevice	id, user_id, token_hash/reference, status ACTIVE/REVOKED, first_seen, approved_by, approved_at, revoked_at, metadata
DeviceChangeRequest	user_id, candidate_device_id, status, requested_at, approved/rejected_by, reason
CourseConfig	course label, timezone, venue coordinates, geofence radius, location accuracy threshold, Google Sheet id, operational defaults
AttendanceSession	id, date, effective_start, effective_end, status, opened_by/at, closed_by/at, cancel/reopen metadata
AttendanceAttempt	user_id, session_id, device reference, timestamp, result/reason, sanitized location evaluation; useful for manual review/security
AttendanceRecord	session_id, user_id, status=present, method, checked_in_at, approved_by, source attempt; UNIQUE(session,user)
AuditLog	actor, action, target type/id, before/after or structured metadata, reason, timestamp, request correlation id

Entity	Key fields / purpose
SheetSyncJob/State	entity/record id, operation, status, attempts, last_error, next_attempt_at, timestamps

15.1 Derived absence

Absence can be stored explicitly at session close or derived as "applicable registered participant without a present record in a closed non-cancelled session." Whichever approach is selected, the system must produce stable historical reporting and must not retroactively mark late registrants absent without an applicability rule.

15.2 Time and timezone

- Store timestamps in UTC internally where practical; store course timezone explicitly and render user-facing times in that timezone.
- Do not rely on client-device clock for authoritative attendance time. Use server time for check-in/open/close/audit timestamps.
- Google Sheets should display local course time consistently.

16. API, background jobs and integration architecture guidance

This section suggests a clean architecture without mandating framework-specific routes. The system should separate transactional attendance decisions from asynchronous integrations.

16.1 Recommended component boundaries

- Web client: responsive participant/admin UI; requests browser geolocation; never decides authorization or final attendance validity by itself.
- Application API/server: authentication, RBAC, session state, device checks, geolocation decision, attendance transaction, manual approvals and audit logging.
- Relational database: authoritative persistence and constraints.
- Background worker/job runner: Google Sheets sync, retries, cleanup/retention tasks, optional email delivery.
- Private object storage: identification photographs.
- Google Sheets API integration: least-privileged service identity restricted to the target workbook where feasible.

16.2 Suggested endpoint families (illustrative)

Area	Illustrative operations
Auth	register, login, logout, forgot/reset password, verify email, session status

Area	Illustrative operations
Participant	me/profile, my attendance history, check-in, location verification submission
Device	my device status, request replacement, candidate status
Session	current status, create/open, close, cancel, reopen, history
Manual verification	pending queue, request detail, approve, reject, emergency manual record
Admin/Roles	participants search, assign course rep, admins list/grant/revoke, venue/config
Audit	admin audit query/filter
Sheets/Operations	sync health, retry, reconcile/rebuild

Transactional boundary

The attendance-record insert, duplicate constraint handling and any critical audit event should occur in a database transaction. Do not call Google Sheets inside that transaction. Commit first, enqueue sync second.

17. Cybersecurity requirements and guardrails

Security should follow the current OWASP Top 10, OWASP ASVS and framework security guidance at implementation time. The following controls are product requirements or strong implementation expectations, regardless of framework.

17.1 Authentication and sessions

- Passwords MUST be hashed with a modern adaptive password hashing algorithm such as Argon2id or an appropriately configured bcrypt/scrypt equivalent. Never encrypt or store plaintext passwords.
- Use HTTPS only in production. Mark authentication cookies Secure and HttpOnly; use an appropriate SameSite policy. Enable HSTS after HTTPS is stable.
- Rotate or invalidate sessions after password reset, high-risk privilege changes and suspected compromise.
- Persistent login may be long-lived for convenience, but use renewable/rotating session or refresh-token patterns rather than a permanent bearer secret where practical.
- Rate-limit login, password-reset, registration, attendance-submission and privileged endpoints. Add progressive delay/lockout carefully to avoid easy denial-of-service against legitimate users.
- Do not reveal whether an email/serial exists more than necessary in password-reset flows.

- Require recent re-authentication for granting admin, changing critical security configuration or other high-risk actions.

17.2 Authorization

- Every protected API route MUST authorize on the server against the current user and requested resource.
- Use deny-by-default RBAC/permission checks. UI visibility is convenience only.
- Prevent insecure direct object references: a participant cannot request another participant's photo/history by changing an ID.
- Course Rep cannot approve own device replacement; role-management endpoints are Admin-only.
- Audit-log access is Admin-only except minimal operational context intentionally surfaced to Course Rep.

17.3 Input, output and web security

- Validate and normalize all inputs server-side even if the UI already validates them.
- Use ORM/parameterized queries. Never concatenate untrusted input into SQL.
- Encode/escape user-controlled output to prevent XSS. Use framework templating/React escaping correctly; sanitize any rich text if introduced later.
- Protect state-changing cookie-authenticated requests from CSRF using framework-recommended tokens/origin checks/SameSite strategy.
- Use a restrictive Content Security Policy where practical and disable unsafe inline script patterns.
- Validate redirects/return URLs to prevent open redirects in login/check-in return flows.
- Set security headers appropriate to the stack (X-Content-Type-Options, Referrer-Policy, frame-ancestors/CSP, Permissions-Policy).
- Do not expose stack traces, SQL errors, internal file paths or secrets to end users.

17.4 Photo/file-upload security

- Limit file size and dimensions; verify actual media type from content.
- Re-encode accepted images to a safe format and strip metadata.
- Use randomized object keys; never trust original filename as a storage path.
- Store privately and authorize every read. Prefer short-lived signed access or proxied authenticated delivery.
- Consider malware scanning if the selected hosting stack supports it affordably, though image re-encoding substantially reduces risk.

17.5 Secrets and third-party integrations

- Keep database credentials, Google service-account material, signing keys and API secrets out of source control and frontend bundles.
- Use environment-specific secret management. Rotate compromised keys promptly.
- Grant the Google integration identity only the permissions required for the target spreadsheet/workbook.
- Log third-party errors without logging credentials or full request bodies containing sensitive data.

17.6 Abuse prevention and audit integrity

- Server time, not client time, is authoritative.
- Attendance endpoints must be idempotent and protected against rapid replay.

- Audit logs should be append-oriented; normal operators must not be able to edit/delete their own audit history.
- Sensitive logs must avoid passwords, raw session/device tokens and full exact GPS traces.
- Monitor unusual patterns such as repeated device-change requests, repeated blocked attendance attempts or many failed logins, but do not automatically accuse participants.

18. Privacy, retention and responsible data handling

The product stores identity information, an identification photograph, attendance history and limited location/device metadata. Data minimization is therefore a product requirement, not an afterthought.

Data	Purpose	Recommended retention / handling
Name, serial, contact	Account and administrative record	Retain while account/course record is needed; follow organizer policy afterward.
Identification photo	Human verification for manual attendance/device change	Private. Recommended deletion after the course plus a short dispute window (e.g., ~90 days) unless a documented policy requires longer.
Attendance records	Official attendance history	Retain according to facilitator/organizational record policy; longer than photo if necessary.
Exact location	Momentary attendance verification	Do not retain by default. If temporarily logged for diagnostics, delete quickly.
Distance/accuracy/result	Troubleshooting/audit	Prefer rounded/minimal values; retain only as long as operationally useful.
Device token	Attendance-device authorization	Secret credential; store securely, revoke on replacement, never expose in reports/logs.
Audit log	Accountability and incident review	Retain through the course and dispute/record-retention window; restrict access.

- Display a concise privacy notice at registration explaining what is collected and why.
- Explain that location is requested only when attempting attendance.
- Do not use identification photographs for automated face recognition without a new explicit product/privacy decision.
- Provide an admin process for correcting inaccurate personal data and handling legitimate deletion requests subject to record obligations.
- Backups must follow the same sensitivity and retention expectations as production data.

19. Error handling, resilience and recovery

User-facing errors should say what happened in plain language and what to do next. The system must never display a success state before the authoritative database commit succeeds.

Failure	Required behavior
Database unavailable before attendance commit	Do not claim success. Show temporary connection/service error and safe Retry. Preserve no false present state.
Google Sheets unavailable after DB commit	Show attendance success. Queue retries; admin sees sync backlog.
Location permission denied	Explain permission requirement; offer retry/settings guidance and Course Rep manual route.
Location timeout/poor accuracy	Offer retry; if physically present, direct to manual verification.
Device token missing/mismatch	Allow account access but block attendance; offer Request Device Change.
Session closes during check-in	Server decides based on authoritative receipt/transaction time and current session rules. Return a deterministic message; do not rely on screen state.
Duplicate concurrent submissions	Return existing attendance record as already checked in.
Photo unavailable to Course Rep	Do not silently approve identity-sensitive request; allow Admin/emergency policy and log the exception.
Background worker down	Attendance still persists in DB. Surface sync-job health to admin and resume when worker returns.

19.1 Idempotency and retry details

- Check-in endpoints SHOULD accept/generate an idempotency key or rely on the database uniqueness invariant so network retries cannot duplicate attendance.
- Google Sheets upserts use stable identifiers and backoff retries.
- Manual approval actions should be safe to double-click; the second action returns the already-final state.
- Role/device-change actions should detect stale state and ask the admin to refresh rather than overwriting a newer decision.

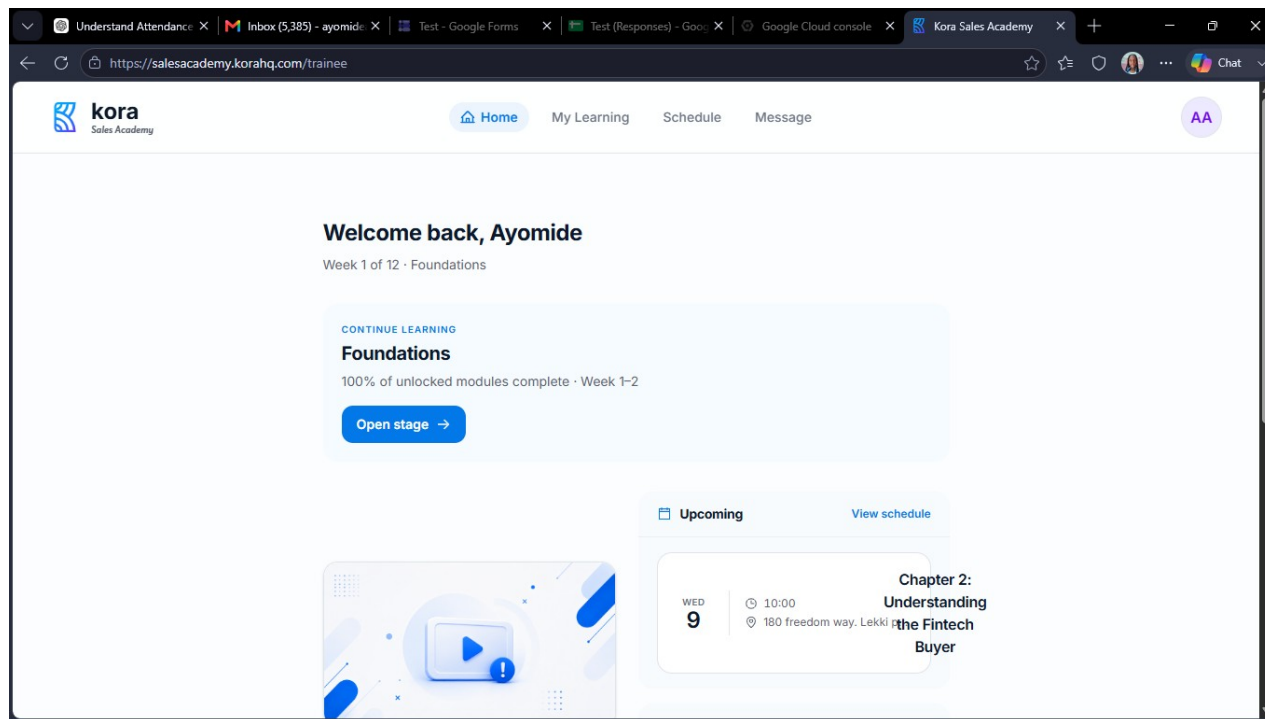
20. Edge-case behavior matrix

Edge case	Expected behavior
Participant scans before session opens	Show not open; create no attendance/pending record.
Participant scans after close	Show closed; no automatic attendance. Admin-only historical correction if justified.
Participant scans twice	Show original success time; no second record.
Two requests arrive simultaneously	DB unique constraint permits one record; other returns existing record.
Participant logs out then back in same registered browser	Device binding remains; attendance can proceed if auth/session checks pass.
Participant logs into their account on another phone	Account access allowed; attendance blocked pending device replacement approval.
Participant clears cookies/site data	Registered device credential is lost; treat as unrecognized device and require device approval.
Participant changes browser on same phone	Likely treated as new attendance device; explain and use replacement process.
Participant uses private/incognito browsing	Discourage/block registration where feasible because persistent device credential may be lost. If token absent later, replacement flow applies.
Someone gets another participant's password	Cannot automatically submit attendance without that participant's active device credential and venue presence.
Same browser attempts another participant account	Do not automatically rebind attendance device; block/surface review.
Registered phone is stolen	User logs in on replacement, requests device change, physically verifies with Course Rep/Admin, new device activates, old device revoked.
Course Rep loses their own attendance device	Admin must approve Course Rep device replacement; Course Rep cannot self-approve.
Only admin loses phone	Admin operations may still be accessible after login because device binding is attendance-specific; if admin is also participant, use another admin where possible for attendance-device approval.

Edge case	Expected behavior
Course Rep absent/late	Admin can operate session as fallback.
Course Rep accidentally closes early	Allow limited same-day audited reopen, or Admin intervention; preserve same session id.
No class on Wednesday	No session → no absence and no summary denominator entry.
Session accidentally opened with no class	Cancel it; exclude from summary; audit reason.
Participant registers after earlier sessions	Do not automatically mark earlier sessions absent without an applicability/enrollment rule.
Participant enters lowercase serial	Normalize to uppercase before validation/storage.
Serial already claimed	Block duplicate; provide login/support/dispute path.
GPS says clearly far away	Reject automatic check-in; physically present user may still approach Course Rep for an auditable manual exception.
GPS poor/ambiguous near venue	Do not hard reject; retry/manual verification.
Google Sheets row manually deleted	DB remains truth. Reconciliation can restore it.
Google Sheets API quota/error	Backoff retries; do not lose attendance.
Admin attempts to remove final admin	Block action.
Course Rep replaced	Old rep privileges revoke immediately; new rep receives operational access.
Name corrected later	Serial remains identity anchor. Reporting may show corrected current name while audit preserves change.
Participant tries to change serial	No self-service. Admin correction only with reason.
Participant wants to change identification photo	Require controlled approval; do not allow silent replacement that undermines manual verification.

21. Design system and responsive UI guide

The interface should be visually inspired by the supplied Kora Sales Academy webpage: light, calm, modern, spacious and blue-accented. It should not copy the reference literally. The attendance product is more operational and mobile-first, but should feel like it belongs to the same visual family.



Visual reference supplied by the product owner - use for tone, spacing, blue accent, light surfaces and restrained navigation; do not reproduce blindly.

21.1 Design principles

- Clean, calm, lightweight, trustworthy and intentionally simple.
- One obvious primary purpose per screen. Status and primary action should dominate; supporting information stays secondary.
- Generous whitespace. Desktop content is centered and width-constrained rather than stretched edge-to-edge.
- One strong blue accent. Avoid competing gradients, neon colors, glassmorphism, excessive shadows and random colorful KPI cards.
- Use cards only where they group related information; do not put every line inside a card.
- Participant UI should feel almost invisible. Admin UI may be denser but must remain calm and easy to scan.
- Participant and admin experiences must look like the same product; permissions change controls, not the entire visual language.

21.2 Color palette

Token	Suggested value	Use
Primary Blue	#0B7FF5	Primary buttons, active navigation,

Token	Suggested value	Use
		links, focus accents
Primary Hover	#066ED8	Hover/pressed primary state
Pale Blue	#F2F8FD	Primary feature cards, highlighted sections
Page Background	#F8FAFC	Overall app background
Surface	#FFFFFF	Cards, forms, navbar
Main Text	#101828	Headings and important text
Secondary Text	#667085	Descriptions, timestamps, metadata
Muted Text	#98A2B3	Placeholders/tertiary labels; never important low-contrast copy
Border	#E4E7EC	Dividers, fields, card outlines
Success	#17A673	Successful attendance/status
Success BG	#ECFDF3	Subtle success surfaces
Warning	#F79009	Manual verification/sync warning
Warning BG	#FFFAEB	Subtle warning surfaces
Error	#D92D20	True errors/rejections/destructive states
Error BG	#FEF3F2	Subtle error surfaces

21.3 Typography

Use a modern sans-serif such as Inter or Manrope. Inter is the preferred reference. Maintain restrained sizes and strong hierarchy rather than oversized marketing typography.

Role	Desktop	Mobile / notes
Page title	28-32px / 700	24-28px / 700

Role	Desktop	Mobile / notes
Section title	20-22px / 650-700	18-20px / 650-700
Card title	17-18px / 600-700	16-18px
Body	14-16px / 400-500	14-16px
Small/meta	12-13px	Do not use for essential actions/messages
Eyebrow label	11-12px / 600-700	Uppercase sparingly; slight letter spacing

21.4 Spacing, radii and elevation

- Use an 8px-based spacing system with 4px allowed for fine gaps. Common values: 4, 8, 12, 16, 24, 32, 40, 48, 64px.
- Mobile page gutters: 16-20px. Tablet: 24-32px. Desktop: 32-48px within a centered max-width container.
- Desktop max content width: approximately 1100-1200px for admin; participant flows may be narrower (700-850px).
- Inputs/buttons: 10-12px radius. Cards: approximately 16px. Large feature cards: 18-20px. Avoid turning everything into pills.
- Prefer subtle borders and pale surfaces to large shadows. If shadow is used, keep it extremely light.

21.5 Navigation

- Desktop/tablet: white top navigation with thin bottom divider, brand/system name left, primary navigation center/left-middle, circular profile avatar right. Active item uses pale-blue rounded background similar to reference.
- Participant mobile: bottom navigation is preferred for Home, Attendance, History, Profile. Keep to four primary items.
- Course Rep/Admin desktop: Overview, Attendance, Participants, History; Administration appears only for admins or as a secondary area.
- On mobile admin, use a compact bottom navigation or simple menu/drawer. Never compress a desktop navbar until labels barely fit.
- Navigation height: roughly 72-80px desktop, 56-64px mobile.

21.6 Cards, buttons and forms

- Primary feature cards may use pale blue without heavy border/shadow. Secondary cards use white with subtle border.

- Primary button: solid blue, white text, 44-48px minimum height, medium-bold, 10-12px radius. Full-width on mobile means full width of the content container, preserving page gutters.
- Secondary button: white, subtle border, dark text. Destructive red only where necessary.
- Forms are single-column on mobile. Desktop may use two columns only for naturally paired fields.
- Labels above inputs, inline validation, visible blue focus state, clear examples. Minimum touch target 44x44px, preferably 48px for major actions.
- Avoid hover-only interactions because mobile is primary.

21.7 Tables and mobile transformation

- Desktop admin data can use lightweight tables with subtle row separators and no heavy vertical grid lines.
- Do not squeeze five-column tables onto narrow mobile. Convert high-value rows into stacked cards/lists or use controlled horizontal scrolling for truly tabular admin data.
- Keep the first/most important identity fields prominent: participant name and serial.

21.8 Loading, empty and error states

- Use button-level loading for small actions (e.g., "Opening attendance...").
- Attendance verification may use a focused spinner/skeleton with "Verifying attendance... This should only take a moment."
- Empty states are understated and helpful, not celebratory marketing.
- Errors state what happened and what the user can do next. Avoid raw codes unless paired with human copy/support reference.
- Do not expose internal GPS coordinates, token state, JWT/database terminology or sync implementation to participants.

21.9 Avoiding generic AI-dashboard aesthetics

- No automatic gradients, glassmorphism, neon glows, decorative blobs or random stock illustrations.
- No icon above every card.
- No meaningless KPI tiles or charts simply because the user is an admin.
- No oversized hero typography, multicolored cards or dark "premium" dashboard theme unless product direction changes.
- No excessive pills/badges. Use status icon + text + subtle color.
- Ask what the user needs at that moment, then show the minimum hierarchy that supports the task.

22. Screen-by-screen UI specification

Screen	Primary contents / behavior
Shared Login	Brand; email/serial input; password; Login; Forgot Password; Create Account. No role selector.
Registration	Name, phone, email, password, serial KSA-XX with example/live normalization, identification photo, device-binding notice, privacy notice, Create Account.
Registration Success	Checkmark, welcome name, serial, explanation that current

Screen	Primary contents / behavior
	browser is registered attendance device, Continue.
Participant Home	Welcome/name/serial; prominent Today's Attendance status; small recent history; device status/profile links.
Attendance Processing	Minimal centered verification state; do not show technical checks.
Attendance Success	Success icon; You're present; date/time; name/serial; You can close this page.
Attendance Not Open/Closed	Neutral status and clear instruction; no destructive error styling.
Location Failure	Warning icon/tint; explanation; Try Again; "If you are physically present, see the Course Representative."
Device Mismatch	Explain not registered attendance device; account still usable; Request Device Change.
Device Change Request	Status, participant serial, instruction to see Course Rep; after approval provide Continue Attendance.
Course Rep Dashboard	Prominent session status and open/close control; live count; manual queue; device-change queue; recent sessions; sync warning.
Open Attendance Dialog	Date, start time, end time, clear confirmation. End must be after start.
Live Attendance	Count, searchable list/table of present participants, timestamps/methods; responsive cards on mobile.
Manual Verification Queue	Participant name/serial, reason, attempted time, status; tap to review.
Manual Verification Detail	Large ID photo, name, serial, reason, attempt time; Approve / Reject. Require reason for emergency override.
Participants	Search by name/serial/email; account status; role markers. Limit sensitive detail in list view.
Attendance History	Session list with date/status/present count/open/close metadata; drill-down.
Admin Overview	Same operational shell plus Administration section and audit/sync health.

Screen	Primary contents / behavior
Role Management	Current Course Rep; change by participant search/serial; admins list; grant/revoke with confirmation.
Audit Log	Filter by action/date/actor/participant; readable event descriptions; no raw secrets.
Profile	Own details, email/phone/name edit, password change, registered attendance device status, request device change, attendance history link.

22.1 Mobile participant example hierarchy

Participant home hierarchy

Welcome back, [Name] / KSA-XX → TODAY'S ATTENDANCE feature card → recent attendance list → bottom navigation. Keep the primary attendance state above the fold on common mobile heights.

22.2 Mobile manual-verification hierarchy

Course Rep identity check

Manual verification → large identification photo → name + KSA-XX → reason + attempted time → full-width Approve Attendance → secondary Reject. This screen is designed for a rep holding a phone while the participant stands in front of them.

23. Accessibility and inclusive interaction requirements

- Target WCAG 2.2 AA for core flows where practical.
- All form controls have programmatic labels, not placeholder-only labels.
- Visible keyboard focus on desktop; logical tab order; no keyboard traps.
- Do not communicate status by color alone; use icon + text and accessible names.
- Minimum interactive target 44x44px; major mobile actions around 48px high.
- Respect browser zoom and text scaling. Avoid fixed heights that clip translated/large text.
- Ensure muted text still meets appropriate contrast for its informational importance.
- Use semantic headings, buttons, links, tables and form error associations.
- Loading indicators should expose accessible status text. Avoid rapid animation and respect reduced-motion preferences.
- Photo upload and location failure instructions must be understandable without technical knowledge.

24. Non-functional requirements

Area	Requirement / target
Performance	Primary participant pages should load quickly on ordinary mobile networks. Avoid large JS bundles and unnecessary images. Attendance decision endpoint should normally respond within a few seconds excluding browser GPS acquisition.
Availability	System should tolerate Google Sheets downtime and background-worker interruption without losing committed attendance.
Scalability	Initial class size is modest, but architecture should not rely on in-memory single-process state for correctness. Database constraints/state must support multiple web processes.
Responsiveness	Support mobile from ~320px upward, tablets, desktop and large desktop. No participant-critical horizontal page scrolling.
Browser support	Current major versions of Chrome/Edge/Safari/Firefox; prioritize Android Chrome and iOS Safari behavior for geolocation/device persistence.
Timezone	Explicit course timezone; server-generated authoritative timestamps.
Data integrity	Transactional attendance insert; uniqueness constraints; migrations; backups; reconciliation.
Maintainability	Clear module boundaries, typed interfaces where stack supports it, linting/formatting, tests, migration discipline, documented environment configuration.

25. Testing and quality assurance

25.1 Automated tests

- Unit tests for serial normalization/validation, geofence decision logic, role permissions, session state transitions, attendance uniqueness handling and sync retry/idempotency.
- Integration tests using a real test database for registration, login, device binding, check-in transaction, manual approval and role changes.
- Authorization tests that explicitly attempt forbidden participant/course-rep access to admin resources.

- Google Sheets integration tests against a dedicated test workbook or mocked adapter, including duplicate retry/upsert behavior and rebuild.
- File-upload tests for invalid types, oversized images, EXIF stripping and private access control.
- End-to-end tests for the core mobile flows using Playwright/Cypress or equivalent. Geolocation should be mocked at browser level for pass/fail/timeout cases.

25.2 Required end-to-end scenarios before launch

1. Fresh participant registers with ksa-xx lowercase → stored/displayed uppercase → device bound → automatic login.
2. Returning participant scans while closed → no record.
3. Admin/Course Rep opens session → participant scans on registered device inside geofence → one present record → success.
4. Participant rescans → already checked in, no duplicate.
5. Participant logs in from new phone → attendance blocked → requests replacement → rep verifies photo → approves → old device revoked → new device succeeds.
6. Course Rep attempts to approve own device change → blocked; admin approval succeeds.
7. GPS denied/poor → participant receives manual instruction → Course Rep approves → record marked Manual Approval.
8. Clearly remote geolocation → automatic rejection.
9. Google Sheets API simulated down → participant still succeeds after DB commit → pending sync → later retry writes exactly one row.
10. Session auto-closes at end time → subsequent check-in blocked.
11. Session cancelled → excluded from Summary denominator.
12. Admin historical correction → visible before/after audit trail.
13. Participant attempts admin URL/API → denied without data leakage.

25.3 Manual device/browser testing

- At least one Android Chrome device, one iPhone Safari device, desktop Chrome/Edge, and a smaller mobile viewport.
- Test location permission: allow, deny, later enable, timeout and poor-accuracy simulation where possible.
- Test browser-data clearing and browser switching to confirm replacement flow.
- Test narrow screens, long names, large text/zoom, slow 3G/4G network throttling and intermittent connectivity.
- Test physical venue GPS before launch and tune radius/accuracy thresholds empirically.

26. Observability, operations and support

- Structured server logs with request/correlation IDs. Never log passwords, raw auth/device tokens or full sensitive payloads.
- Error tracking/alerting for server exceptions and repeated background-job failures.
- Health checks for web application, database connectivity and background worker.
- Admin-visible Google Sheets sync backlog and last successful sync time.
- Operational metrics MAY include check-in success/failure counts by reason, manual approval count, device-change count and session durations, provided they do not expose unnecessary personal data.

- Automated backups of the database and, if applicable, private photo storage metadata; periodically verify restoration procedure.
- Document a simple support procedure for serial disputes, lost phones, password resets, GPS failure and historical attendance disputes.

27. Development, deployment and engineering practices

The developer has freedom of stack, but professional software-development practices are required because the product handles identity and attendance records.

27.1 Preferred reference stack (non-binding)

Layer	Good options / selection guidance
Frontend	React/Next.js with TypeScript, or another mature responsive web framework. Server-rendered/hybrid is fine; avoid an unnecessarily heavy SPA if not needed.
Backend	TypeScript Node framework (e.g., NestJS/Next server APIs), Django/FastAPI, Laravel, Rails, or equivalent mature framework with strong auth/ORM/security ecosystem.
Database	PostgreSQL strongly preferred for constraints, transactions and reliability.
Background jobs	Redis-backed queue such as BullMQ/Celery/RQ, managed queue, or framework scheduler. For this small system, a reliable DB-backed job runner is also acceptable.
Object storage	Private S3-compatible/cloud object storage for identification photos; local private storage only if deployment/backup strategy makes it safe.
Sheets	Official Google Sheets API using a least-privileged service account or OAuth/service identity appropriate to ownership.
Hosting	Any reputable HTTPS-capable platform that supports persistent database, secrets, background jobs and private storage.

27.2 Engineering workflow

- Use Git with a protected main branch and pull-request/code-review workflow where team size permits.

- Separate development, test/staging and production configuration. Never test destructive flows against production data or the production Google Sheet.
- Use database migrations committed to source control; never manually mutate production schema without a migration plan.
- Enforce formatter/linter and static type checking where available in CI.
- Run automated tests in CI before production deployment.
- Pin/dependably manage dependencies and monitor security advisories. Keep framework/runtime versions supported.
- Use environment variables/secret manager for secrets. Provide a sanitized `.env.example/documentation` without real credentials.
- Document local setup, migrations, seed/bootstrap admin creation, Google Sheet setup, deployment, backup/restore and role recovery.
- Use feature flags/configuration for tunable geofence/retry/retention values rather than hard-coding business values throughout the codebase.
- Prefer small, explicit modules/services for auth, attendance, device management, Sheets sync and audit rather than one monolithic controller.

27.3 Deployment safeguards

- Production HTTPS and correct secure-cookie behavior must be verified before real attendance use; browser geolocation requires secure context.
- Run migrations safely before/with deploy. Have rollback or forward-fix plan.
- Seed/bootstrap the first admin via a secure one-time CLI/admin process. Remove/disable bootstrap path after use.
- Do not expose development debug mode in production.
- Configure CORS narrowly if frontend/backend are separated; do not use wildcard credentials origins.
- Restrict database and object-storage network/access permissions to the application where feasible.

28. Delivery phases and release acceptance criteria

28.1 Suggested implementation phases

Phase	Scope
Phase 1 - Foundation	Project setup, database, auth, roles, registration validation/photo storage, shared login, participant/admin shells, bootstrap admin.
Phase 2 - Attendance core	Session lifecycle, permanent QR route, registered-device binding, geolocation decision, attendance records, duplicate protection, participant success/error states.
Phase 3 - Operations	Course Rep assignment, live dashboard, manual verification, device-change approval, audit log, historical controls.
Phase 4 - Google Sheets	Master Register, dated tabs, Summary, asynchronous

Phase	Scope
	idempotent sync, retry/backoff, reconciliation.
Phase 5 - Hardening	Security review, accessibility, cross-device GPS testing, performance, backups, monitoring, retention tasks, edge-case tests.
Phase 6 - Pilot	Run at the real venue with a small set of users, tune geofence/accuracy thresholds, fix UX friction, then launch to full class.

28.2 MVP release acceptance checklist

- ☐ Normal participant can register once with name, phone, email, password, valid unique KSA-XX and identification photo.
- ☐ Lowercase/mixed-case serial prefix normalizes to uppercase; malformed serials are rejected clearly.
- ☐ Registration binds current browser as the active attendance device and explains the rule.
- ☐ Shared login works; participant cannot access admin functions.
- ☐ Admin can assign one participant as Course Rep and add/remove admins without allowing zero admins.
- ☐ Course Rep can configure/open/close attendance; session auto-closes at end time.
- ☐ Permanent QR only records attendance while a valid session is open.
- ☐ Registered device + location + duplicate checks happen server-side before present is recorded.
- ☐ GPS uncertainty has retry/manual fallback; clearly remote reading is rejected.
- ☐ Manual approval displays protected photo and is auditable.
- ☐ New device cannot submit attendance until approved; approval revokes old device; Course Rep cannot self-approve own replacement.
- ☐ Database prevents duplicate attendance under concurrency.
- ☐ Google Sheets contains Master Register, dated session output and Summary; Sheets outage cannot lose attendance; retries are idempotent.
- ☐ All privileged actions generate meaningful audit records.
- ☐ Mobile participant flow is usable on common Android/iPhone sizes and admin screens remain usable on both phone and desktop.
- ☐ Security controls in Section 17 are implemented and no secrets/photos/tokens leak to Google Sheets or logs.
- ☐ Backup, monitoring and basic operational documentation exist before production use.

Appendix A - Session and attendance state summary

Session state transitions (conceptual):

Session state

DRAFT/CONFIGURING → SCHEDULED (optional) → OPEN → CLOSED. OPEN/CLOSED may become CANCELLED when explicitly invalidated. CLOSED may be REOPENED under audited rules and then CLOSED again.

Attendance attempt outcomes (conceptual):

Attempt state

PASS → final PRESENT record; LOCATION_UNCERTAIN / DEVICE_CHANGE_REQUIRED → pending human/device workflow; CLEARLY_REMOTE → rejected attempt; DUPLICATE → return existing PRESENT record. ABSENT is finalized/derived when a non-cancelled session closes.

Appendix B - Example Google Sheets output

B.1 Master Register

Serial Number	Full Name	Phone Number	Email	Registered At
KSA-01	Jane Doe	080...	jane@example.com	2026-09-03 14:22
KSA-02	John Smith	081...	john@example.com	2026-09-04 09:17

B.2 Session tab - 2026-09-09

Serial	Name	Status	Check-in	Method	Location	Approved By
KSA-01	Jane Doe	Present	09:07	QR	Verified	
KSA-02	John Smith	Absent				
KSA-03	Mary Ade	Present	09:31	Manual Approval	Manual	KSA-17

Appendix C - Recommended configuration defaults

Setting	Recommended starting value	Notes
Course timezone	Africa/Lagos	Make explicit; do not infer from client.
Geofence radius	~200 m	Configurable; tune at real venue.
Max automatic GPS accuracy	~150 m	Configurable; poor accuracy routes to retry/manual.
Sheets retry	Immediate + seconds + 1m + 5m + 15m	Use exponential backoff/jitter and alert

Setting	Recommended starting value	Notes
	+ 30-60m	persistent failure.
Photo retention	Course end + ~90 days	Configurable to organizer policy.
Session end	Entered by Course Rep/Admin	Automatic close at end.
Participant device count	1 active	Replacement revokes previous.
Admins	>=1; preferably >=2 operationally	System blocks removal of last admin.

Appendix D - Glossary

Term	Definition
Attendance device	The participant's currently approved browser/device installation represented by a protected server-issued credential; not an immutable hardware ID.
Attendance session	One actual physical attendance event with a controlled open window.
Attendance attempt	A check-in attempt and its evaluation, whether successful, uncertain or rejected.
Attendance record	The authoritative final present record for one participant in one session.
Course Representative	A designated participant with operational attendance permissions assigned by an Admin.
Admin / Facilitator	Overseer role with role management, configuration, audit and historical correction privileges.
Manual verification	Human identity/physical-presence fallback performed by Course Rep/Admin using the registration photo.
Geofence	Configurable allowed radius around the venue used for proximity verification.
Source of truth	The application database. Google Sheets is a reporting projection.

Appendix E - Final product philosophy

Security proportionality

The system should be substantially more resistant to casual proxy attendance than a paper sign-in sheet, without turning normal attendance into a high-friction identity ceremony. Put complexity in exception handling and auditability, not in the ordinary participant flow.

Design philosophy

Clean, light, mobile-first attendance product inspired by a modern education SaaS interface: generous whitespace, crisp typography, white and very pale blue surfaces, one vivid blue accent, subtle borders, restrained rounding/shadows, clear hierarchy and highly functional responsive layouts. Usability and information clarity take precedence over decoration.

END OF PRD